

TP5, eleve : Authentification, JWT et cryptographie

(A07 / A02 / A08)

- Jour 2 - Duree : ~1h30 - Dossier : `jour2-ctf/` (port 8002)

Contexte

Prouver qui on est (authentification), rester connecte (session), et proteger l'integrite des jetons et des secrets (crypto). Trois domaines ou les erreurs sont frequentes et couteuses.

Mise en place

La stack du Jour 2 doit tourner (`cd jour2-ctf && docker compose up -d --build`).

Challenges

03 - La porte du capitaine (identifiants par default)

Objectif : entrer avec un compte qui garde ses identifiants d'usine. - Indice 1 : quel est le couple identifiant/mot de passe le plus teste au monde ? - Indice 2 : essayez sur le compte d'administration.

08 - Le sceau du capitaine (JWT alg:none)

Objectif : devenir admin sur `/api/me` sans connaitre la cle de signature. - Indice 1 : appelez `/api/me` sans jeton : on vous en donne un exemple. Decodez-le (jwt.io). - Indice 2 : un JWT = header.payload.signature (base64url). Que contient le header ? - Indice 3 : certains serveurs acceptent l'algorithme `none` (aucune signature). Forgez un header `{"alg":"none"}`, un payload avec `"role":"admin"`, et une signature vide.

07 - Le message en bouteille (Base64 pris pour du chiffrement)

Objectif : lire le "jeton chiffre" du capitaine (`/token`). - Indice 1 : recuperez le jeton sur `/token`. - Indice 2 : est-il vraiment chiffre, ou juste encode ? - Indice 3 : Base64 se decode sans aucune cle.

Bonus 12 - Le coffre mal ferme (brute force)

Un compte a un mot de passe tres faible et le login n'a aucune limite de tentatives. A vous de jouer, sans DoS : restez raisonnable (petite liste de mots de passe courants).

Outils

jwt.io (decoder/forging), `base64 -d`, un petit script Python, Burp Intruder (avec parcimonie).

Validation

Soumettez chaque flag sur <http://localhost:8002/scoreboard>.

Livrable attendu

Pour chaque challenge : méthode, cause racine, et contre-mesure (vous reutiliserez au TP6).